

Information Assurance and Security

College of Engineering and Information Technology

Information Assurance and Security

Suppose you visit an e-commerce website such as your bank, stock broker, etc.

Before you type in highly sensitive information, you'd like to have some assurance that your information will be protected. Do you (have such assurance)? How can you know?

What security-relevant things do you want to happen, or not happen when you use such a website?



Information Assurance and Security

You might want:

- Privacy of your data
- Protection against phishing
- Integrity of your data
- Authentication
- Authorization
- Confidentiality
- Non-repudiation
- Availability
- What else?



Information Assurance and Security

5 pillars of information assurance

Availability	Integrity	Authentication	Confidentiality	Nonrepudiation
Ensures information is ready for use and at the required performance level.	Guarantees data, associated systems only accessible or modifiable by authorized users.	Ensures users are who they say they are (i.e., user names/passwords, biometrics, digital certificates and security tokens).	Limits access or places restrictions on data like personally identifiable information/ classified corporate data.	Ensures individuals cannot deny an action because a system provides proof of the action.



Information Assurance and Security

According to the DoD definition, these are some aspects of information needing protection:

Availability: timely, reliable access to data and information services for authorized users;

Integrity: protection against unauthorized modification or destruction of information;

Confidentiality: assurance that information is not disclosed to unauthorized persons;

Authentication: security measures to establish the validity of a transmission, message, or originator.

Non-repudiation: assurance that the sender is provided with proof of a data delivery and recipient is provided with proof of the sender's identity, so that neither can later deny having processed the data.



Information Assurance and Security

This class is about *Information Assurance*; so what is "information"? How does information differ from data?

"Information is data endowed with relevance and purpose. Converting data into information thus requires knowledge. Knowledge by definition is specialized." (Blyth and Kovacich, p. 17)



And what characteristics should information possess to be useful?
It should be: accurate, timely, complete, verifiable, consistent, available.



Information Assurance and Security

It is the practice of assuring information and managing risks related to the use, processing, storage, and transmission of information or data and the systems and processes used for those purposes.

Information assurance includes protection of the integrity, availability, authenticity, non-repudiation and confidentiality of user data.



Information Assurance and Security

The act of ensuring that data is not lost when critical issues arise. These issues include but are not limited to: natural disasters, computer/server malfunction, physical theft, or any other instance where data has the potential of being lost. Since most information is stored on computers in our modern era, information assurance is typically dealt with by IT security specialists.

One of the most common methods of providing information assurance is to have an off-site backup of the data in case one of the mentioned issues arises.



What is Information Assurance?

What about "assurance"? What does that mean? Assurance from what or to do what? Is it context-dependent?

According to the U.S. Department of Defense, IA involves:

> *Actions taken that protect and defend information and information systems by ensuring their availability, integrity, authentication, confidentiality and non-repudiation. This includes providing for restoration of information systems by incorporating protection, detection and reaction capabilities.*

Information Assurance (IA) is the study of how to protect your information assets from destruction, degradation, manipulation and exploitation. But also, how to recover should any of those happen.



What is Information Assurance?

According to Debra Herrmann (*Complete Guide to Security and Privacy Metrics*), IA should be viewed as spanning four security engineering domains:

- physical security
- personnel security
- IT security
- operational security

> *The simple truth is that IT security cannot be accomplished in a vacuum, because there are a multitude of dependencies and interactions among all four security engineering domains.* (Herrmann, p. 10)



Security Domain

Quotes from Debra Herrmann, *Complete Guide to Security and Privacy Metrics*:

"*Physical security* refers to the protection of hardware, software, and data against physical threats to reduce or prevent disruptions to operations and services and loss of assets."

"*Personnel security* is a variety of ongoing measures taken to reduce the likelihood and severity of accidental and intentional alteration, destruction, misappropriation, misuse, misconfiguration, unauthorized distribution, and unavailability of an organization's logical and physical assets, as the result of action or inaction by insiders and known outsiders, such as business partners."



Security Domain

"*IT security* is the inherent technical features and functions that collectively contribute to an IT infrastructure achieving and sustaining confidentiality, integrity, availability, accountability, authenticity, and reliability."

"*Operational security* involves the implementation of standard operational security procedures that define the nature and frequency of the interaction between users, systems, and system resources, the purpose of which is to

1. achieve and sustain a known secure system state at all times, and
2. prevent accidental or intentional theft, release, destruction, alteration, misuse, or sabotage of system resources."



Security Domain

Into which of these would you put the following?

- enforcing hard-to-guess passwords
- encrypting your hard drive
- locking sensitive documents in a safe
- stationing a marine guard outside an embassy
- assigning security clearances to staffers
- using SSL for data transfers
- having off-site backup of documents



Information Security

- sometimes shortened to **InfoSec**, is the practice of defending information from unauthorized access, use, disclosure, disruption, modification, perusal, inspection, recording or destruction. It is a general term that can be used regardless of the form the data may take (electronic, physical, etc...)



Information Security

- Two major aspects of Information Security

IT security: Sometimes referred to as computer security, Information Technology Security is information security applied to technology (most often some form of computer system). It is worthwhile to note that a computer does not necessarily mean a home desktop.

Information assurance: The act of ensuring that data is not lost when critical issues arise. These issues include but are not limited to: natural disasters, computer/server malfunction, physical theft, or any other instance where data has the potential of being lost



Computer Security

- It is a branch of computer technology known as information security as applied to computers and networks. The objective of computer security includes protection of information and property from theft, corruption, or natural disaster, while allowing the information and property to remain accessible and productive to its intended users.



Computer Security

Computer Security - generic name for the collection of tools designed to protect data and to thwart hackers

Network Security - measures to protect data during their transmission

Internet Security - measures to protect data during their transmission over a collection of interconnected networks



End of Presentation





Attacks on Computers and Computer Security



Why We Need Information Security?

- **Threats** - A threat is an object, person, or other entity that represents a constant danger to an asset.

Threat Categories

- Acts of human error or failure
- Compromises to intellectual property
- Deliberate acts of espionage or trespass
- Deliberate acts of information extortion
- Deliberate acts of sabotage or vandalism
- Deliberate acts of theft
- Deliberate software attack
- Forces of nature
- Deviations in quality of service
- Technical hardware failures or errors
- Technical software failures or errors
- Technological obsolesce



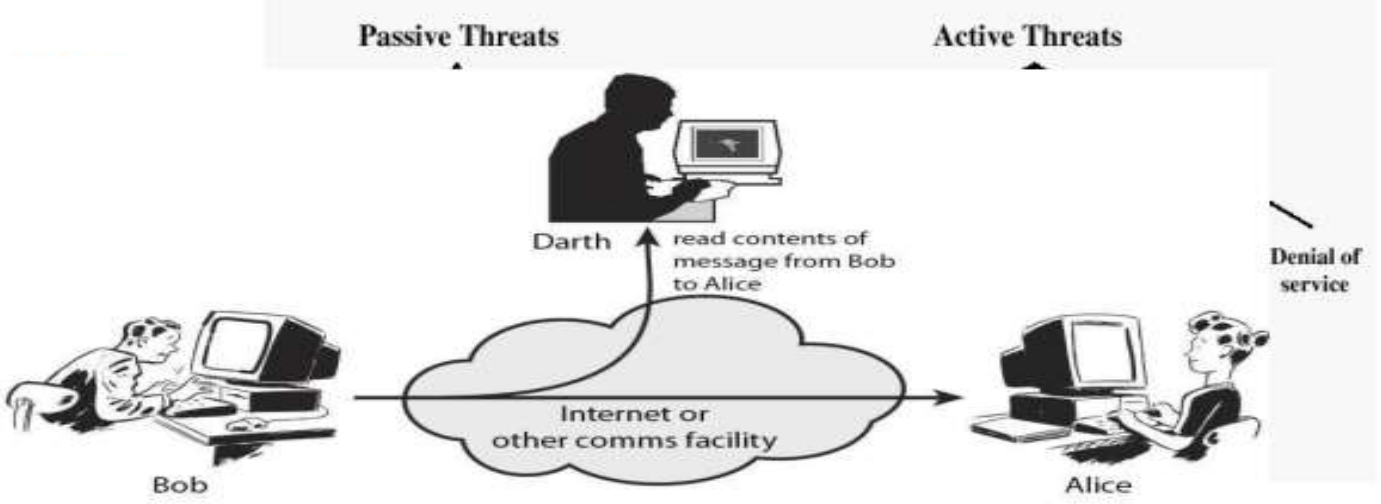
- **Computer Security** - generic name for the collection of tools designed to protect data and to thwart hackers.
- **Network Security** - measures to protect data during their transmission.
- **Internet Security** - measures to protect data during their transmission over a collection of interconnected networks.
  - ASPECTS OF SECURITY
  - consider 3 aspects of information security:
    - Security Attack
    - Security Mechanism
    - Security Service



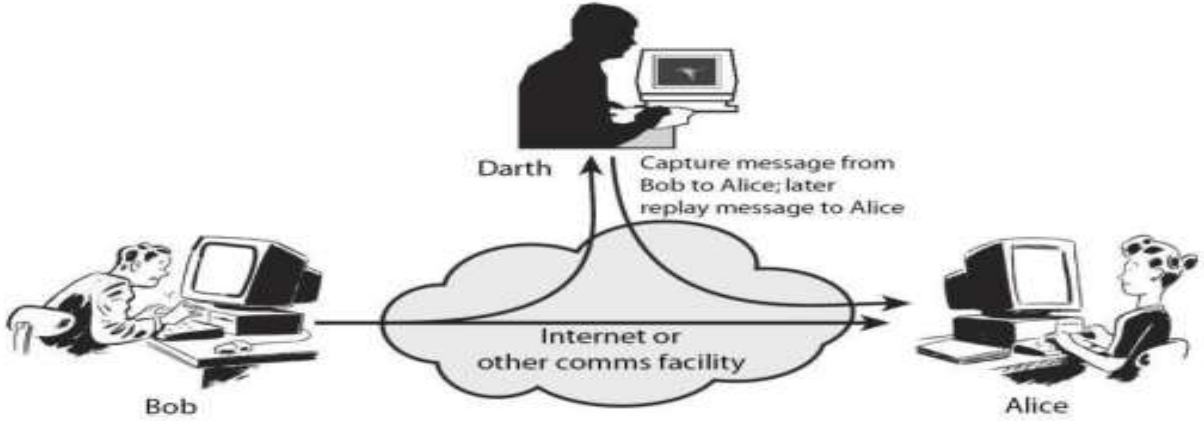
Security Attack

- any action that compromises the security of information owned by an organization
- information security is about how to prevent attacks, or failing that, to detect
- attacks on information-based systems
- often threat & attack used to mean same thing
- have a wide range of attacks
- can focus of generic types of attacks
  - Passive
  - Active

Passive Attack



Active Attack





- **INTERRUPTION** - An asset of the system is destroyed or becomes unavailable or unusable. It is an attack on availability.
- **Examples:**
  - Destruction of some hardware
  - Jamming wireless signals
  - Disabling file management systems
- **INTERCEPTION** - An unauthorized party gains access to an asset. Attack on confidentiality.
- **Examples:**
  - Wire tapping to capture data in a network.
  - Illicitly copying data or programs
  - Eavesdropping
- **MODIFICATION** - When an unauthorized party gains access and tampers an asset. Attack is on Integrity.
- **Examples:**
  - Changing data file
  - Altering a program and the contents of a message



- **FABRICATION** - An unauthorized party inserts a counterfeit object into the system. Attack on Authenticity. Also called impersonation
- **Examples:**
  - Hackers gaining access to a personal email and sending message
  - Insertion of records in data files
  - Insertion of spurious messages in a network

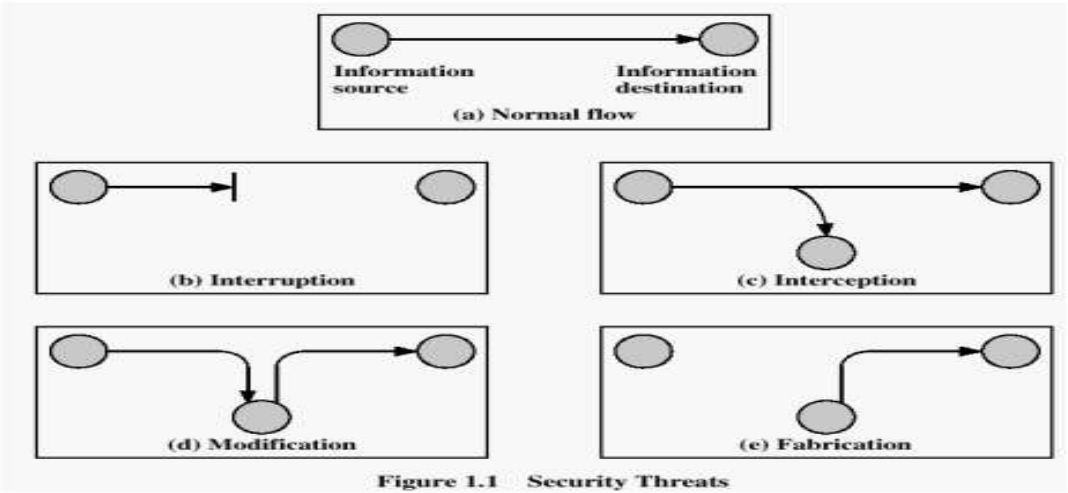


Figure 1.1 Security Threats



Summary Table

Threat Type	What Happens	Security Property Violated
Interruption	Data is blocked	Availability
Interception	Data is accessed	Confidentiality
Modification	Data is altered	Integrity
Fabrication	Fake data is created	Authenticity



- **Security Services** - It is a processing or communication service that is provided by a system to give a specific kind of production to system resources. Security services implement security policies and are implemented by security mechanisms.
- **Confidentiality** is the protection of transmitted data from passive attacks. It is used to prevent the disclosure of information to unauthorized individuals or systems.
- **Authentication** - This service assures that a communication is authentic. For a single message transmission, its function is to assure the recipient that the message is from intended source. For an ongoing interaction two aspects are involved.
- **Peer entity authentication**: Verifies the identities of the peer entities involved in communication. Provides use at time of connection establishment and during data transmission. Provides confidence against a masquerade or a replay attack.
- **Data origin authentication**: Assumes the authenticity of source of data unit, but does not provide protection against duplication or modification of data units. Supports5 applications like electronic mail, where no prior interactions take place between communicating entities.



- **Integrity** means that data cannot be modified without authorization. Like confidentiality, it can be applied to a stream of messages, a single message or selected fields within a message.
  TWO TYPES OF INTEGRITY SERVICES ARE AVAILABLE:
- **Connection-Oriented Integrity Service**: This service deals with a stream of messages, assures that messages are received as sent, with no duplication, insertion, modification, reordering or replays. Destruction of data is also covered here. Hence, it attends to both message stream modification and denial of service.
- **Connectionless-Oriented Integrity Service**: It deals with individual messages regardless of larger context, providing protection against message modification only. An integrity service can be applied with or without recovery. Because it is related to active attacks, major concern will be detection rather than prevention. If a violation is detected and the service reports it, either human intervention or automated recovery machines are required to recover.
- **Non-repudiation** prevents either sender or receiver from denying a transmitted message. This capability is crucial to e-commerce. Without it an individual or entity can deny that he, she or it is responsible for a transaction, therefore not financially liable.



- **Access Control** - This refers to the ability to control the level of access that individuals or entities have to a network or system and how much information they can receive. It is the ability to limit and control the access to host systems and applications via communication links. For this, each entity trying to gain access must first be identified or authenticated, so that access rights can be tailored to the individuals.
- **Availability** - It is defined to be the property of a system or a system resource being accessible and usable upon demand by an authorized system entity. The availability can significantly be affected by a variety of attacks, some amenable to automated counter measures i.e authentication and encryption and others need some sort of physical action to prevent or recover from loss of availability of elements of a distributed system.



SPECIFIC SECURITY MECHANISMS

Incorporated into the appropriate protocol layer in order to provide some of the OSI security services,

Encipherment: It refers to the process of applying mathematical algorithms for converting data into a form that is not intelligible. This depends on algorithm used and encryption keys.

Digital Signature: The appended data or a cryptographic transformation applied to any data unit allowing to prove the source and integrity of the data unit and protect against forgery.

Access Control: A variety of techniques used for enforcing access permissions to the system resources.



- **Data Integrity**: A variety of mechanisms used to assure the integrity of a data unit or stream of data units.
- **Authentication Exchange**: A mechanism intended to ensure the identity of an entity by means of information exchange.
- **Traffic Padding**: The insertion of bits into gaps in a data stream to frustrate traffic analysis attempts.
- **Routing Control**: Enables selection of particular physically secure routes for certain data and allows routing changes once a breach of security is suspected.
- **Notarization**: The use of a trusted third party to assure certain properties of a data exchange

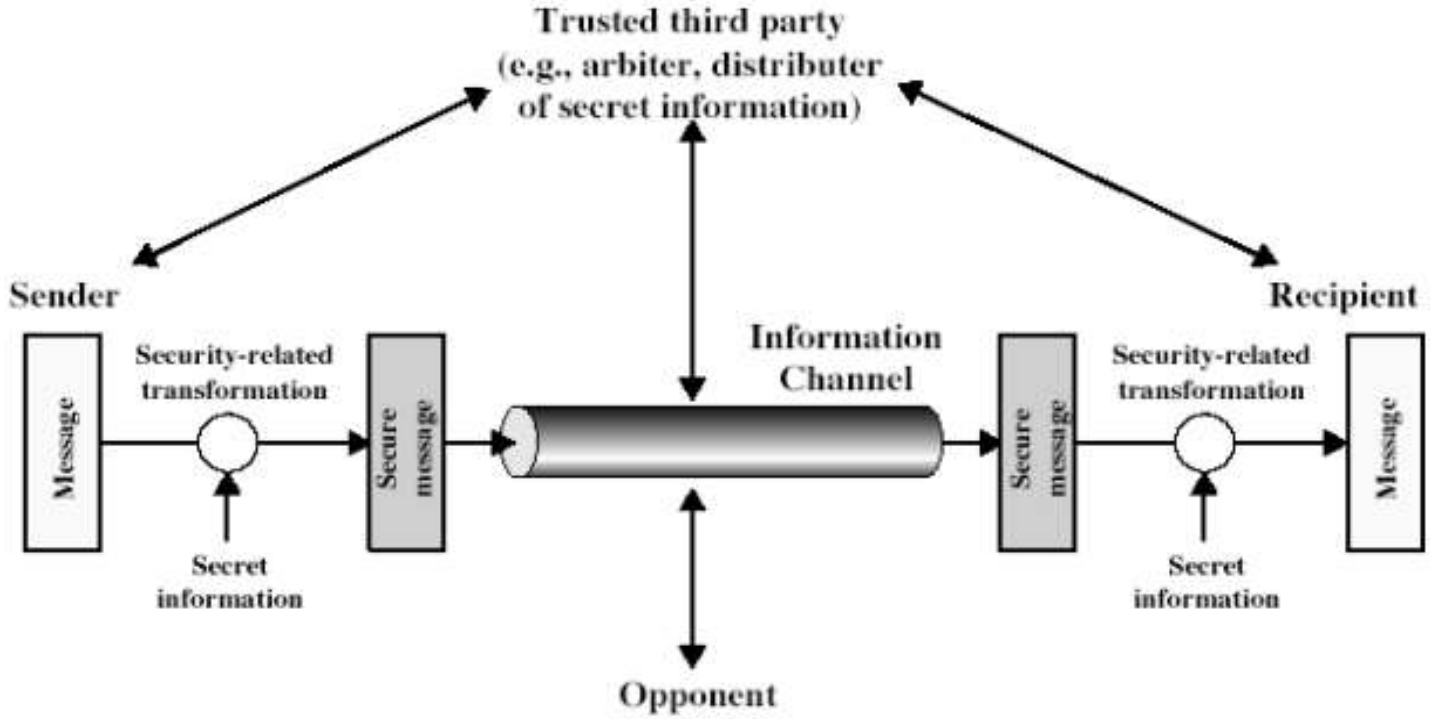


Pervasive Security Mechanisms

These are not specific to any particular OSI security service or protocol layer.

- **Trusted Functionality**: That which is perceived to correct with respect to some criteria.
- **Security Level**: The marking bound to a resource (which may be a data unit) that names or designates the security attributes of that resource.
- **Event Detection**: It is the process of detecting all the events related to network security.
- **Security Audit Trail**: Data collected and potentially used to facilitate a security audit, which is an independent review and examination of system records and activities.
- **Security Recovery**: It deals with requests from mechanisms, such as event handling and management functions, and takes recovery actions.

MODEL FOR NETWORK SECURITY





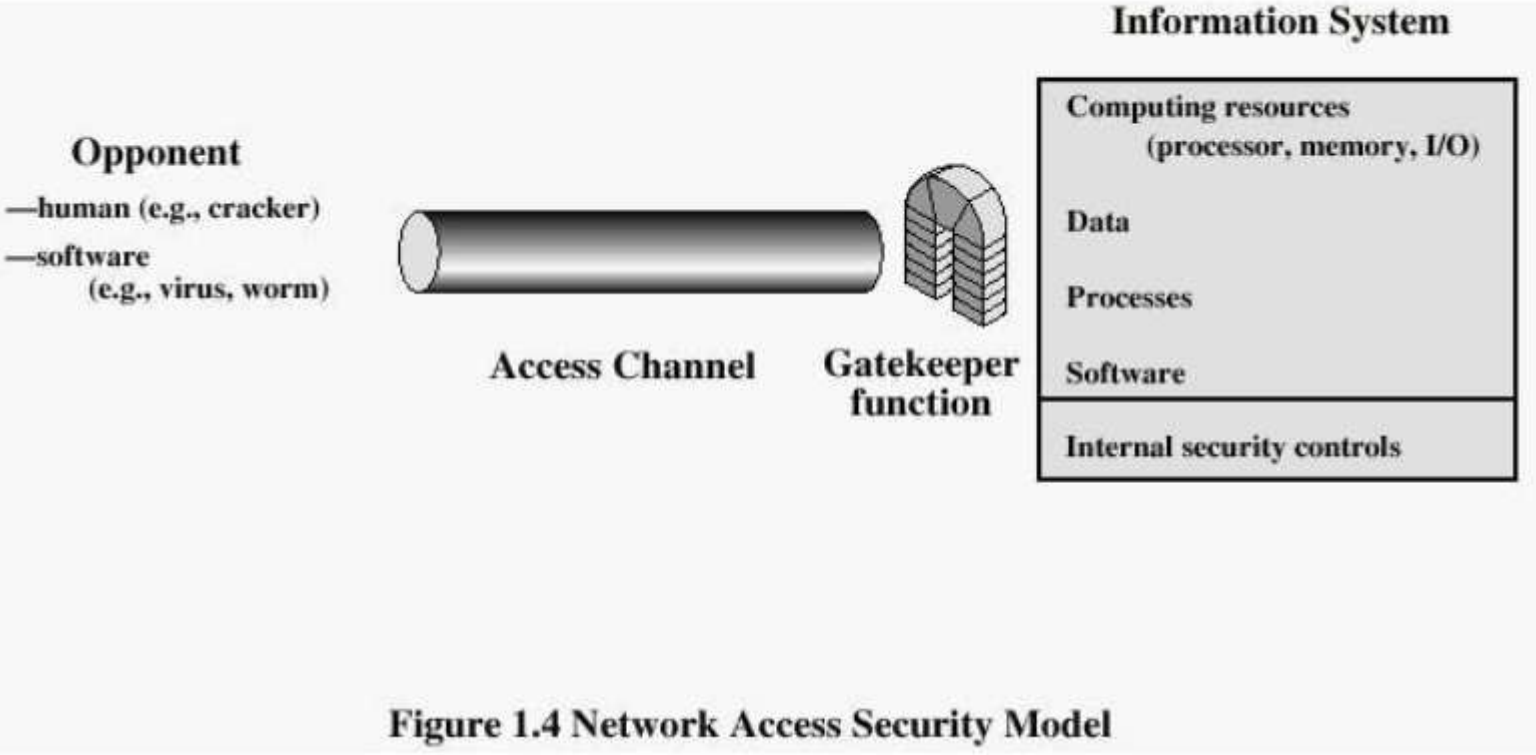


Figure 1.4 Network Access Security Model



- **Data** is transmitted over network between two communicating parties, who must cooperate for the exchange to take place.
- A **logical information** channel is established by defining a route through the internet from source to destination by use of communication protocols by the two parties. Whenever an opponent presents a threat to confidentiality, authenticity of information, security aspects come into play.
- **Information access threats** intercept or modify data on behalf of users who should not have access to that data
- **Service threats** exploit service flaws in computers to inhibit use by legitimate users Viruses and worms are two examples of software attacks inserted into the system by means of a disk or also across the network.
- The security mechanisms needed to cope with unwanted access fall into two broad categories.



SOME BASIC TERMINOLOGIES USED

- **CIPHER TEXT** - the coded message.
- **CIPHER** - algorithm for transforming plaintext to ciphertext.
- **KEY** - info used in cipher known only to sender/receiver.
- **ENCIPHER (ENCRYPT)** - converting plaintext to ciphertext.
- **DECIPHER (DECRYPT)** - recovering ciphertext from plaintext.
- **CRYPTOGRAPHY** - study of encryption principles/methods.
- **CRYPTANALYSIS** (CODEBREAKING) - the study of principles/ methods of deciphering ciphertext without knowing key.
- **CRYPTOLOGY** - the field of both cryptography and cryptanalysis.



CRYPTANALYSIS

- The process of attempting to discover X or K or both is known as cryptanalysis.
- The strategy used by the cryptanalysis depends on the nature of the encryption scheme and the information available to the cryptanalyst. There are various types of cryptanalytic attacks based on the amount of information known to the cryptanalyst.
- **Cipher text only** – A copy of cipher text alone is known to the cryptanalyst.
- **Known plaintext** – The cryptanalyst has a copy of the cipher text and the corresponding plaintext.
- **Chosen plaintext** – The cryptanalysts gains temporary access to the encryption machine. They cannot open it to find the key, however; they can encrypt a large number of suitably chosen plaintexts and try to use the resulting cipher texts to deduce the key.
- **Chosen cipher text** – The cryptanalyst obtains temporary access to the decryption machine, uses it to decrypt several string of symbols, and tries to use the results to deduce the key



CLASSICAL ENCRYPTION TECHNIQUES

- **SUBSTITUTION TECHNIQUES** - A substitution technique is one in which the letters of plaintext are replaced by other letters or by numbers or symbols. If the plaintext is viewed as a sequence of bits, then substitution involves replacing plaintext bit patterns with cipher text bit patterns.
- **CAESAR CIPHER** - The earliest known use of a substitution cipher and the simplest was by Julius Caesar. The Caesar cipher involves replacing each letter of the alphabet with the letter standing 3 places further down the alphabet. e.g., plain text : pay more money
- **Cipher text**: SDB PRUH PRQHB
- **MONOALPHABETIC CIPHERS** - Here, Plaintext characters are substituted by a different alphabet stream of characters shifted to the right or left by n positions. When compared to the Caesar ciphers, these monoalphabetic ciphers are more secure as each letter of the ciphertext can be any permutation of the 26 alphabetic characters leading to 26! orgreater than 4 x 1026 possible keys.



- **PLAYFAIR CIPHERS** - It is the best known multiple –letter encryption cipher which treats diagrams in the plaintext as single units and translates these units into cipher text diagrams.
- **HILL CIPHER** - It is also a multi letter encryption cipher. It involves substitution of ‘m’ ciphertext letters for ‘m’ successive plaintext letters.
- **POLYALPHABETIC CIPHERS**
- **Polyalphabetic** means that the same letter of a message can be represented by different letters when encoded.
- **Vigenere cipher** is a polyalphabetic cipher based on using successively shifted alphabets, a different shifted alphabet for each of the 26 English letters.



TRANSPOSITION TECHNIQUES

- **Rail fence** is simplest of such cipher, in which the plaintext is written down as a sequence of diagonals and then read off as a sequence of rows.
- **Row Transposition Ciphers** - A more complex scheme is to write the message in a rectangle, row by row, and read the message off, column by column, but permute the order of the columns.
- **STEGANOGRAPY** - A plaintext message may be hidden in any one of the two ways. The methods of steganography conceal the existence of the message, whereas the methods of cryptography render the message unintelligible to outsiders by various transformations of the text.
- **Character marking** – selected letters of printed or typewritten text are overwritten in pencil. The marks are ordinarily not visible unless the paper is held to an angle to bright light.



- **Invisible ink** – a number of substances can be used for writing but leave no visible trace until heat or some chemical is applied to the paper.
- **Pin punctures** – small pin punctures on selected letters are ordinarily not visible unless the paper is held in front of the light.
- **Typewritten correction ribbon** – used between the lines typed with a black ribbon, the results of typing with the correction tape are visible only under a strong light.
- **Drawbacks of Steganography**
- Requires a lot of overhead to hide a relatively few bits of information.
- Once the system is discovered, it becomes virtually worthless.



Process Flow (Activity)

- The sender/source creates message
- The sender must employ encryption using secret key
- Ciphertext transmits through in-secure channel
- An attacker may attempt an attack
- Recipient decrypts using secret key
- Original message is recovered

OVERVIEW OF THE SYSTEM MAINTENANCE

LEESON 2

WHAT IS SYSTEM MAINTENANCE

- The process of managing change to application systems while maintaining the integrity.

Why do we need maintenance?

System seldom remains static

WHO WILL REQUEST?

- Users who will interact with the system

  senior management

  staff

  clients

  customers

  internal auditor

  external auditor

HOW DO WE MAKE REQUEST TO CHANGE THE SYSTEM?

- Change request form

  Name

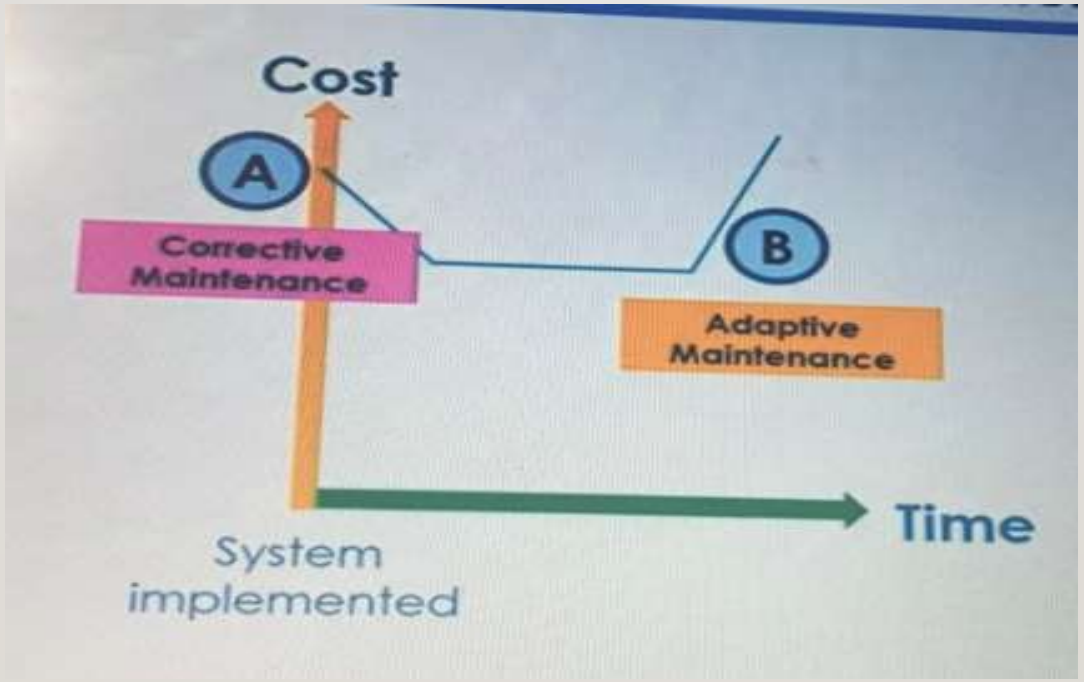
  Date

  Reason to Change

  Expected benefit

  Priority

HOW WOULD THE SYSTEM MAINTENANCE COST CHANGE?



WHAT ARE THE SYSTEM MAINTENANCE PRACTICES

1. CORRECTIVE MAINTENANCE
2. PREVENTIVE MAINTENANCE
3. ADAPTIVE MAINTENANCE
4. PERFECTIVE MAINTENANCE

WHAT ARE THE SYSTEM MAINTENANCE PRACTICES

- **Corrective Maintenance** – Fixing errors or bugs discovered after the system has been deployed.

- **Preventive Maintenance** – Modifying the system to prevent future problems and improve maintainability.

- **Adaptive Maintenance** – Updating the system to adapt to changes in the environment (e.g., OS
updates, hardware changes, regulations)

- **Perfective Maintenance** – Enhancing or improving system performance, usability, or adding new features based on user feedback.

WHAT ARE THE SYSTEM MAINTENANCE PRACTICES

Corrective Maintenance

Fixing defects found after deployment.

- **Examples:**
- Fixing a login error that prevents users from accessing their accounts
- Correcting incorrect tax computation in a payroll system
- Repairing a broken hyperlink in a website
- Debugging an app that crashes when uploading images

WHAT ARE THE SYSTEM MAINTENANCE PRACTICES

Preventive Maintenance

Improving the system to prevent future problems.

Examples:

- Refactoring messy code to make it easier to maintain
- Updating antivirus software
- Replacing outdated libraries before they cause security risks
- Performing database cleanup to prevent performance issues

WHAT ARE THE SYSTEM MAINTENANCE PRACTICES

Adaptive Maintenance

Modifying the system due to environmental changes.

Examples:

- Updating a system to work with a new operating system version
- Modifying software to comply with new data privacy regulations
- Adjusting a mobile app to support new screen sizes
- Updating a payment system to support a new e-wallet provider

WHAT ARE THE SYSTEM MAINTENANCE PRACTICES

Perfective Maintenance

Enhancing or improving system performance or adding features.

Examples:

- Adding dark mode to a mobile application
- Improving system speed and performance
- Enhancing the user interface for better usability
- Adding new reporting features to an information system

WHAT KIND OF MAINTENANCE PRACTICE ARE THEY?

- SCENARIO 1
- Patching the Internet browser's plug in software

WHAT KIND OF MAINTENANCE PRACTICE ARE THEY?

- SCENARIO 2
- Re-design the data entry form to provide user friendly interface to the customers.

WHAT KIND OF MAINTENANCE PRACTICE ARE THEY?

- SCENARIO 3
- Installation of anti virus software on a UNIX server to comply with regulatory requirements

WHAT KIND OF MAINTENANCE PRACTICE ARE THEY?

- SCENARIO 4
- Setting up additional firewall rules addressing a newly discovered network exploit technique

WHAT KIND OF MAINTENANCE PRACTICE ARE THEY?

- SCENARIO 5
- Increase in number of digits allowed in the "Telephone Number" field of the system responding to the telephone numbers reform in the country to be able to handle new longer telephone number.

WHAT KIND OF MAINTENANCE PRACTICE ARE THEY?

- SCENARIO 6
- Adding an Italian language interface to the banking system which currently has Simplified/Traditional Chinese and English Interface.

3

Legal, Ethical, and Professional Issues in Information Security

Learning Objectives

Upon completion of this material, you should be able to:

- Use this chapter as a guide for future reference on laws, regulations, and professional organizations
- Differentiate between laws and ethics
- Identify major national laws that relate to the practice of information security
- Understand the role of culture as it applies to ethics in information security

Introduction

- You must understand scope of an organization's legal and ethical responsibilities
- To minimize liabilities/reduce risks, the information security practitioner must:
  - Understand current legal environment
  - Stay current with laws and regulations
  - Watch for new issues that emerge

Law and Ethics in Information Security

- Laws: rules that mandate or prohibit certain societal behavior
- Ethics: define socially acceptable behavior
- Cultural mores: fixed moral attitudes or customs of a particular group; ethics based on these
- Laws carry sanctions of a governing authority; ethics do not

Types of Law

- Civil
- Criminal
- Tort
- Private
- Public

Relevant U.S. Laws (General)

- Computer Fraud and Abuse Act of 1986 (CFA Act)
- National Information Infrastructure Protection Act of 1996
- USA Patriot Act of 2001
- Telecommunications Deregulation and Competition Act of 1996
- Communications Decency Act of 1996 (CDA)
- Computer Security Act of 1987

Privacy

- One of the hottest topics in information security
- Is a "state of being free from unsanctioned intrusion"
- Ability to aggregate data from multiple sources allows creation of information databases previously unheard of

Privacy of Customer Information

- Privacy of Customer Information Section of common carrier regulation
- Federal Privacy Act of 1974
- Electronic Communications Privacy Act of 1986
- Health Insurance Portability and Accountability Act of 1996 (HIPAA), aka Kennedy-Kassebaum Act
- Financial Services Modernization Act, or Gramm-Leach-Bliley Act of 1999

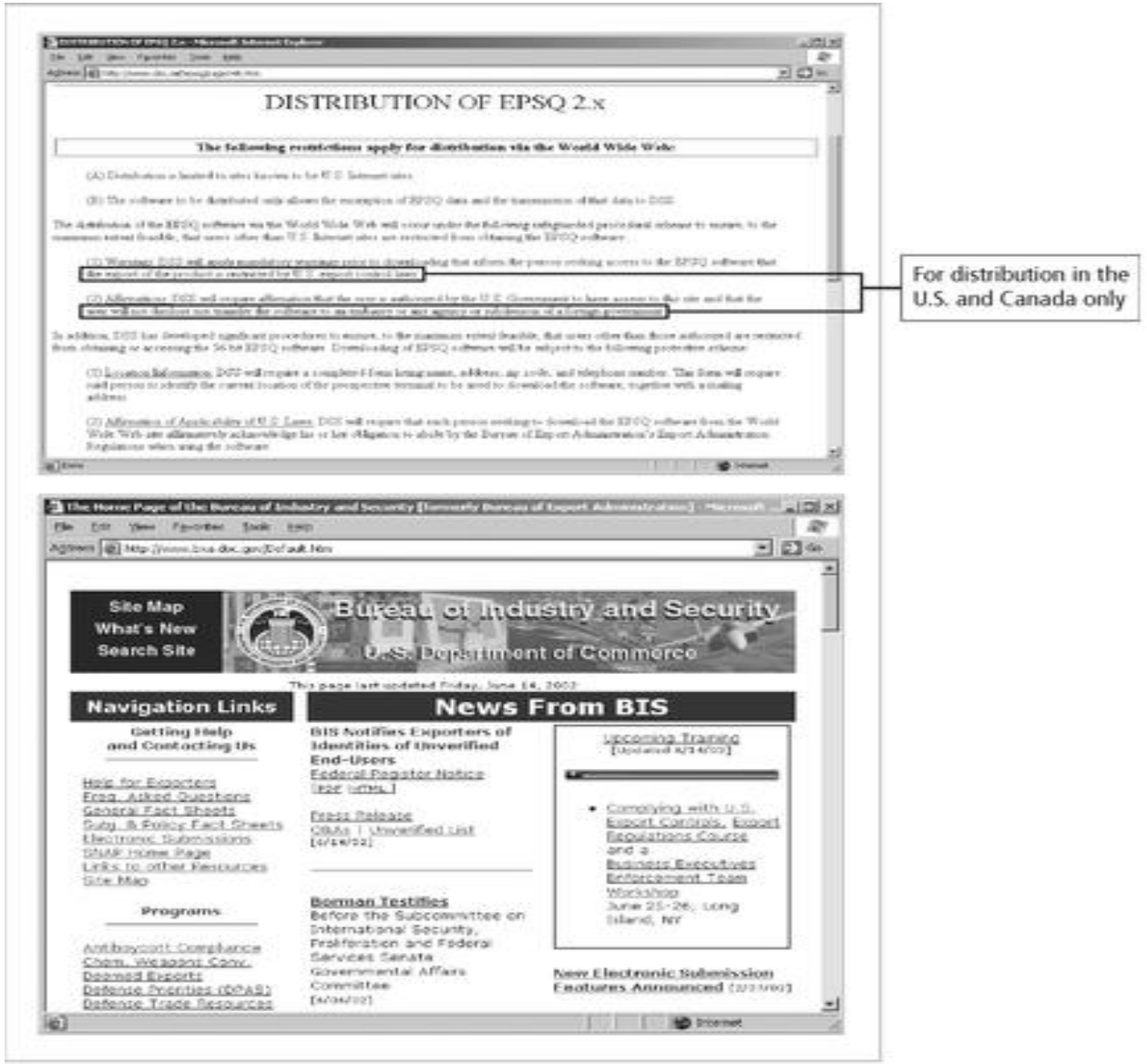


FIGURE 3-2 Export and Espionage

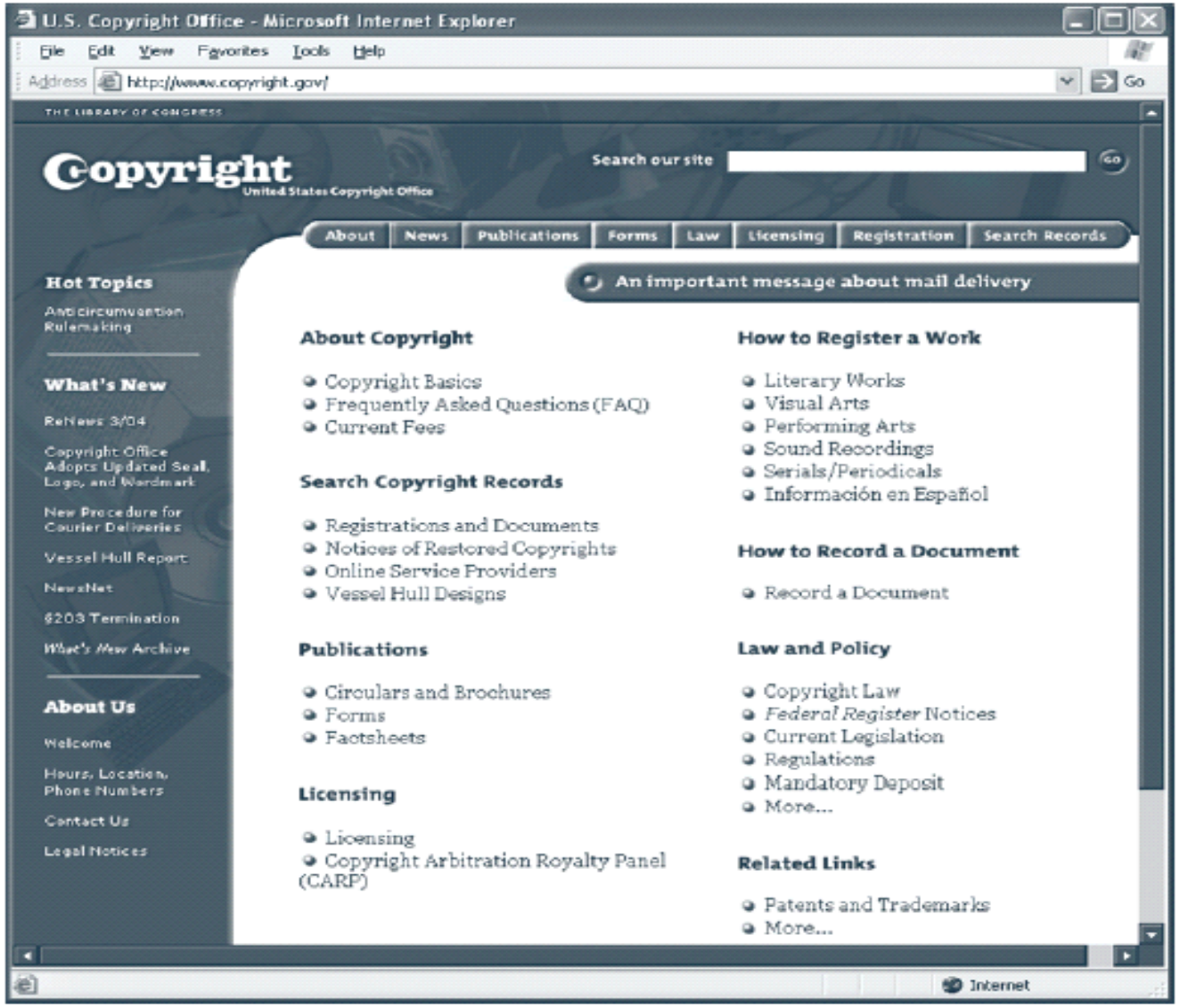


FIGURE 3-2 The U.S. Copyright Office Web Site

Export and Espionage Laws

- Economic Espionage Act of 1996 (EEA)
- Security And Freedom Through Encryption Act of 1999 (SAFE)

U.S. Copyright Law

- Intellectual property recognized as protected asset in the U.S.; copyright law extends to electronic formats
- With proper acknowledgement, permissible to include portions of others' work as reference
- U.S. Copyright Office Web site: www.copyright.gov

Freedom of Information Act of 1966 (FOIA)

- Allows access to federal agency records or information not determined to be matter of national security
- U.S. government agencies required to disclose any requested information upon receipt of written request
- Some information protected from disclosure

State and Local Regulations

- Restrictions on organizational computer technology use exist at international, national, state, local levels
- Information security professional responsible for understanding state regulations and ensuring organization is compliant with regulations

International Laws and Legal Bodies

- European Council Cyber-Crime Convention:
  - Establishes international task force overseeing Internet security functions for standardized international technology laws
  - Attempts to improve effectiveness of international investigations into breaches of technology law
  - Well received by intellectual property rights advocates due to emphasis on copyright infringement prosecution
  - Lacks realistic provisions for enforcement

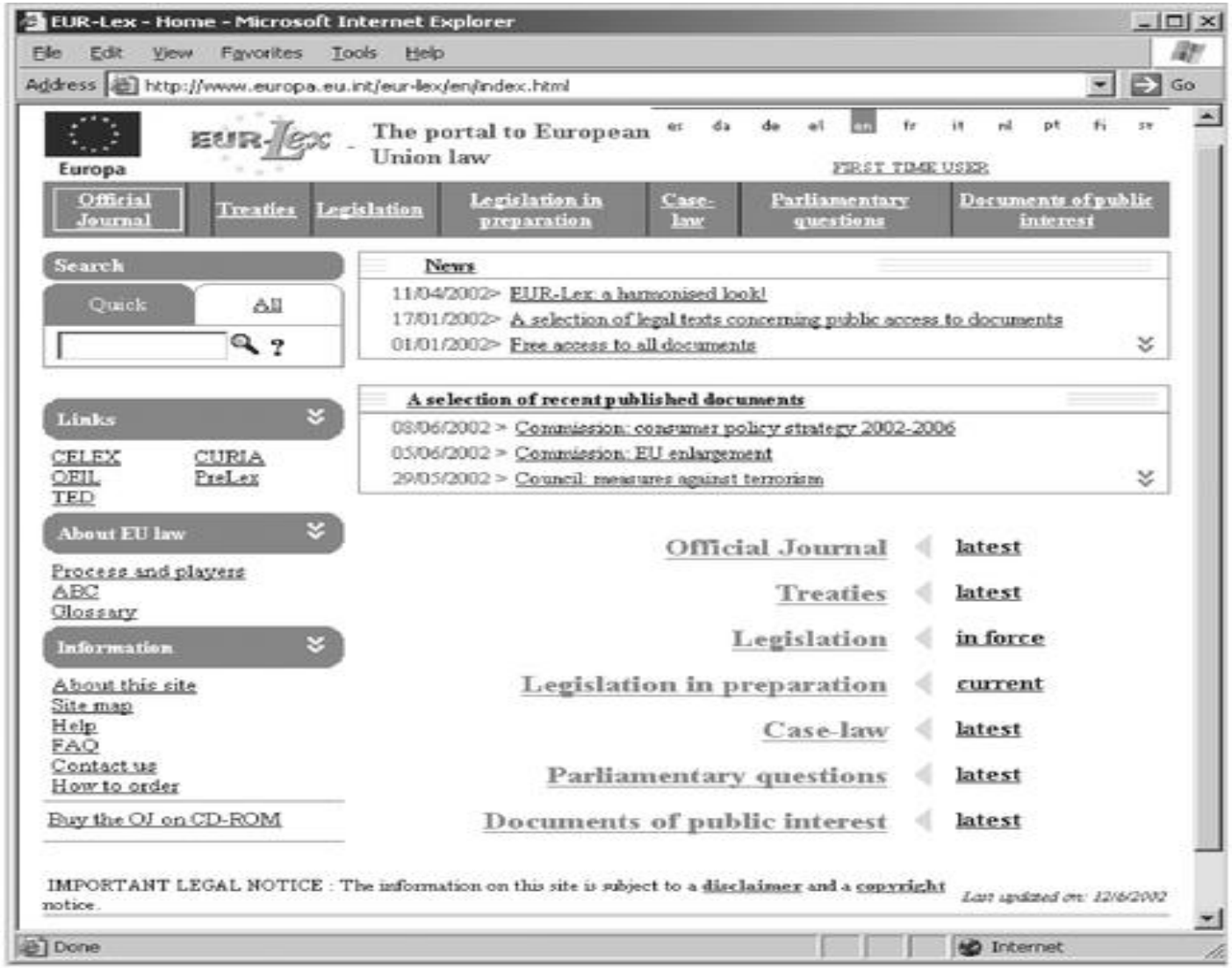


FIGURE 3-5 EU Law Portal

Digital Millennium Copyright Act (DMCA)

- U.S. contribution to international effort to reduce impact of copyright, trademark, and privacy infringement
- A response to European Union Directive 95/46/EC, which adds protection to individuals with regard to processing and free movement of personal data

United Nations Charter

- Makes provisions, to a degree, for information security during information warfare (IW)
- IW involves use of information technology to conduct organized and lawful military operations
- IW is relatively new type of warfare, although military has been conducting electronic warfare operations for decades



FIGURE 3-6 UN International Law Web site

Policy Versus Law

- Most organizations develop and formalize a body of expectations called policy
- Policies serve as organizational laws
- To be enforceable, policy must be distributed, readily available, easily understood, and acknowledged by employees

Ethics and Information Security

The Ten Commandments of Computer Ethics[6]

From The Computer Ethics Institute

1. Thou shalt not use a computer to harm other people.
2. Thou shalt not interfere with other people's computer work.
3. Thou shalt not snoop around in other people's computer files.
4. Thou shalt not use a computer to steal.
5. Thou shalt not use a computer to bear false witness.
6. Thou shalt not copy or use proprietary software for which you have not paid.
7. Thou shalt not use other people's computer resources without authorization or proper compensation.
8. Thou shalt not appropriate other people's intellectual output.
9. Thou shalt think about the social consequences of the program you are writing or the system you are designing.
10. Thou shalt always use a computer in ways that ensure consideration and respect for your fellow humans.

Ethical Differences Across Cultures

- Cultural differences create difficulty in determining what is and is not ethical
- Difficulties arise when one nationality's ethical behavior conflicts with ethics of another national group
- Example: many of ways in which Asian cultures use computer technology is software piracy

Ethics and Education

- Overriding factor in leveling ethical perceptions within a small population is education
- Employees must be trained in expected behaviors of an ethical employee, especially in areas of information security
- Proper ethical training vital to creating informed, well prepared, and low-risk system user

Deterrence to Unethical and Illegal Behavior

- Deterrence: best method for preventing an illegal or unethical activity; e.g., laws, policies, technical controls
- Laws and policies only deter if three conditions are present:
  - Fear of penalty
  - Probability of being caught
  - Probability of penalty being administered

Codes of Ethics and Professional Organizations

- Several professional organizations have established codes of conduct/ethics
- Codes of ethics can have positive effect; unfortunately, many employers do not encourage joining of these professional organizations
- Responsibility of security professionals to act ethically and according to policies of employer, professional organization, and laws of society

Association of Computing Machinery (ACM)

- ACM established in 1947 as "the world's first educational and scientific computing society"
- Code of ethics contains references to protecting information confidentiality, causing no harm, protecting others' privacy, and respecting others' intellectual property

International Information Systems Security Certification Consortium, Inc. $(ISC)^2$

- Non-profit organization focusing on development and implementation of information security certifications and credentials
- Code primarily designed for information security professionals who have certification from $(ISC)^2$
- Code of ethics focuses on four mandatory canons

System Administration, Networking, and Security Institute (SANS)

- Professional organization with a large membership dedicated to protection of information and systems
- SANS offers set of certifications called Global Information Assurance Certification (GIAC)

Information Systems Audit and Control Association (ISACA)

- Professional association with focus on auditing, control, and security
- Concentrates on providing IT control practices and standards
- ISACA has code of ethics for its professionals

Computer Security Institute (CSI)

- Provides information and training to support computer, networking, and information security professionals
- Though without a code of ethics, has argued for adoption of ethical behavior among information security professionals

Information Systems Security Association (ISSA)

- Nonprofit society of information security (IS) professionals
- Primary mission to bring together qualified IS practitioners for information exchange and educational development
- Promotes code of ethics similar to $(ISC)^2$, ISACA and ACM

Other Security Organizations

- Internet Society (ISOC): promotes development and implementation of education, standards, policy and education to promote the Internet

- Computer Security Division (CSD): division of National Institute for Standards and Technology (NIST); promotes industry best practices and is important reference for information security professionals

Other Security Organizations (continued)

- CERT Coordination Center (CERT/CC): center of Internet security expertise operated by Carnegie Mellon University

- Computer Professionals for Social Responsibility (CPSR): public organization for anyone concerned with impact of computer technology on society

Key U.S. Federal Agencies

- Department of Homeland Security (DHS)
- Federal Bureau of Investigation's National Infrastructure Protection Center (NIPC)
- National Security Agency (NSA)
- U.S. Secret Service

Organizational Liability and the Need for Counsel

- Liability is legal obligation of an entity; includes legal obligation to make restitution for wrongs committed
- Organization increases liability if it refuses to take measures known as due care
- Due diligence requires that an organization make valid effort to protect others and continually maintain that level of effort

Summary

- Laws: rules that mandate or prohibit certain behavior in society; drawn from ethics
- Ethics: define socially acceptable behaviors; based on cultural mores (fixed moral attitudes or customs of a particular group)
- Types of law: civil, criminal, tort law, private, public

Summary

- Relevant U.S. laws:
  - Computer Fraud and Abuse Act of 1986 (CFA Act)
  - National Information Infrastructure Protection Act of 1996
  - USA Patriot Act of 2001
  - Telecommunications Deregulation and Competition Act of 1996
  - Communications Decency Act of 1996 (CDA)
  - Computer Security Act of 1987

Homework

- Relevant U.S. laws:
  - Computer Fraud and Abuse Act of 1986 (CFA Act)
  - National Information Infrastructure Protection Act of 1996
  - USA Patriot Act of 2001
  - Telecommunications Deregulation and Competition Act of 1996
  - Communications Decency Act of 1996 (CDA)
  - Computer Security Act of 1987
- These are relevant U.S. Laws on Information Security. Pick one law and prepare a 10 minutes presentation on it. One week.

Summary

- Many organizations have codes of conduct and/or codes of ethics
- Organization increases liability if it refuses to take measures known as due care
- Due diligence requires that organization make valid effort to protect others and continually maintain that effort

Risk Management

Once we know our weaknesses, they cease to do us any harm

G.C. (GEORG CHRISTOPH) LICHTENBERG (1742-1799)

GERMAN PHYSICIST, PHILOSOPHER

Learning Objectives

Upon completion of this material, you should be able to:

- Define risk management: risk identification, and risk control
- Understand how risk is identified and assessed
- Describe the risk mitigation strategy options for controlling risks
- Evaluate risk controls and formulate a cost benefit analysis
- Understand how to maintain and perpetuate risk controls

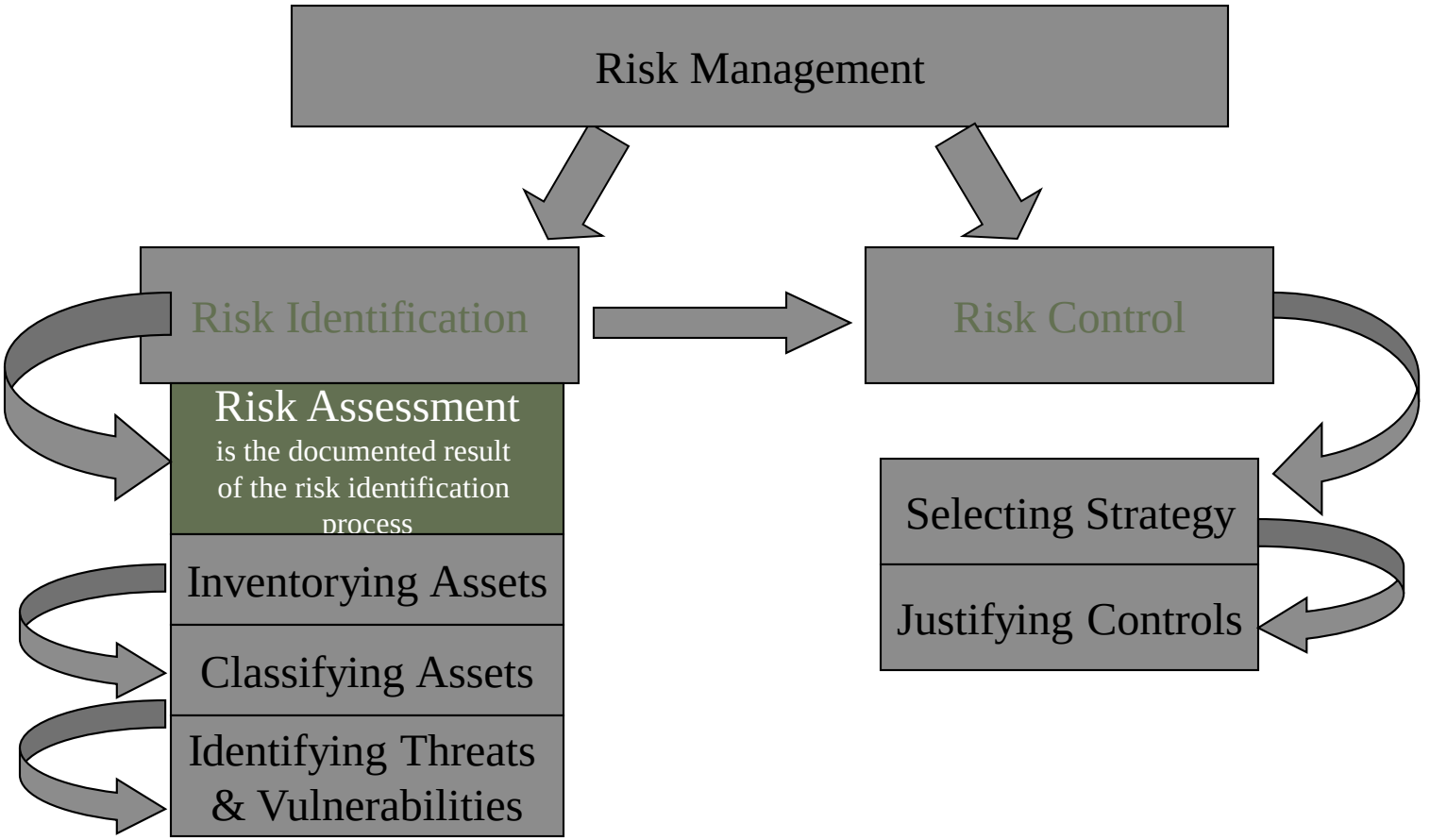
Introduction

Risk management: process of identifying and controlling risks facing an organization

Risk identification: process of examining an organization's current information technology security situation

Risk control: applying controls to reduce risks to an organizations data and information systems

Components of Risk Management



Competitiveness

Information Technology Role

- Began as a advantage
- Now falling behind is a disadvantage

Availability is a necessity

An Overview of Risk Management

Know yourself

- Understand the technology and systems in your organization

Know the enemy

- Identify, examine, understand threats

Role of Communities of Interest

- Information Security
- Management and Users
- Information Technology

The Roles of the Communities of Interest

1) ***Information security*****, 2)** ***management and users*****, 3)** ***information technology*** all must work together

Management review:

- Verify completeness/accuracy of asset inventory
- Review and verify threats as well as controls and mitigation strategies
- Review cost effectiveness of each control
- Verify effectiveness of controls deployed

Risk Identification

Assets are targets of various threats and threat agents

Risk management involves identifying ***organization's assets*** and identifying ***threats/vulnerabilities***

Risk identification begins with identifying organization's assets and assessing their value

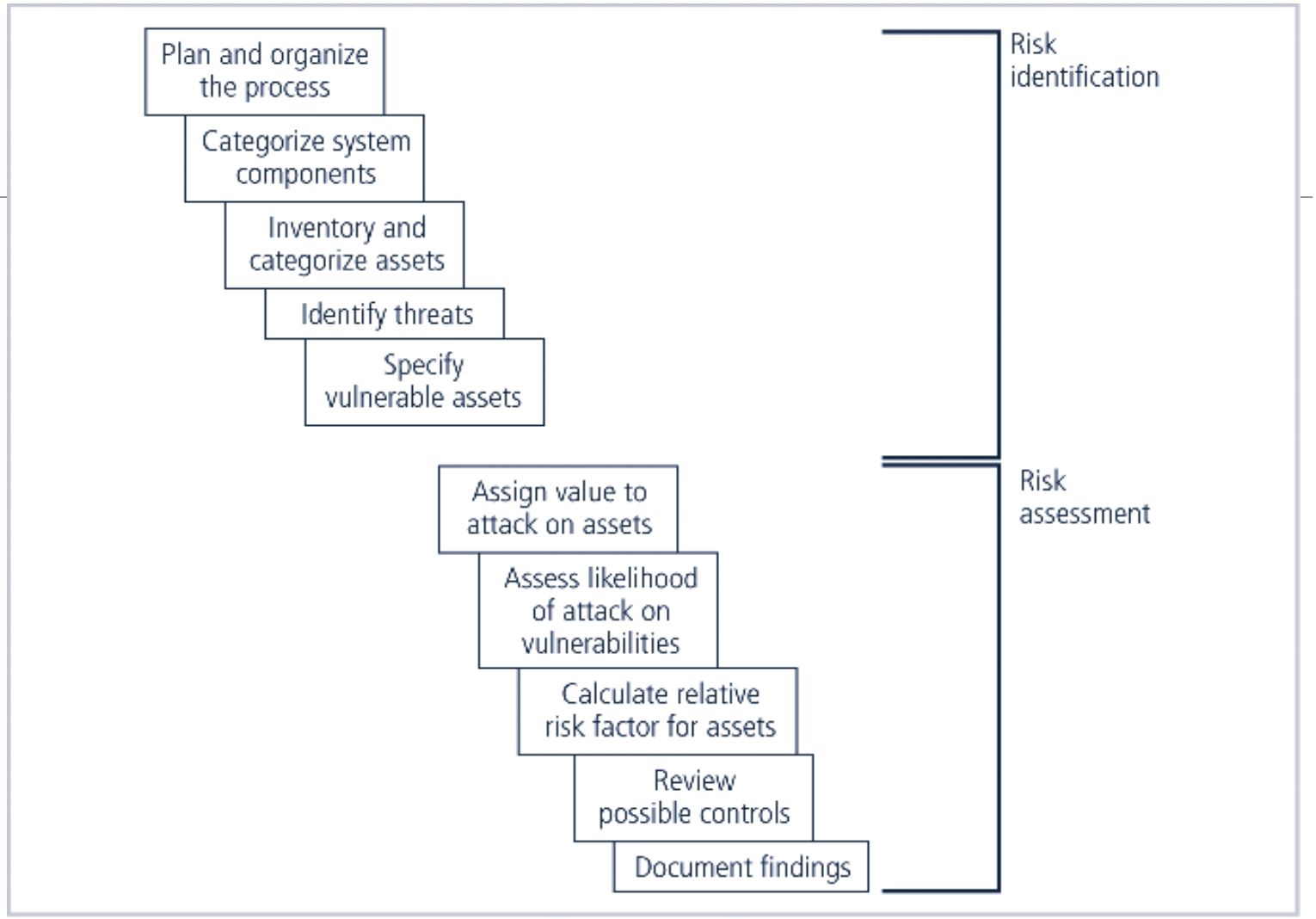


FIGURE 4-2 **Components of Risk Identification**

Asset Identification and Valuation

Iterative process; begins with identification of assets, including all elements of an organization's system (people, procedures, data and information, software, hardware, networking)

Assets are then classified and categorized

Asset Identification & Valuation

Traditional System Components	SecSDLC and risk management system components	
People	Employee	Trusted employees Other staff
	Non-employees	People at trusted organizations / Strangers
Procedures	Procedures	IT & business standards procedures IT & business standards procedures
Data	Information	Transmission, Processing, Storage
Software	Software	Applications, Operating systems, Security components
Hardware	System devices and peripherals	Systems and peripherals Security devices
	Networking components	Intranet components Internet or DMZ components

People, Procedures, and Data Asset Identification

Human resources, documentation, and data information assets are more difficult to identify

People with knowledge, experience, and good judgment should be assigned this task

These assets should be recorded using reliable data-handling process

People, Procedures, and Data Asset Identification

Asset attributes for *people:* position name/number/ID; supervisor; security clearance level; special skills

- Try to avoid names

Asset attributes for *procedures*

- Intended purpose
- Relationship to software, hardware, network elements
- Storage location

Asset attributes for data

- classification; owner/creator/manager; data structure size; data structure used; online/offline; location; backup procedures employed

Hardware, Software, and Network Asset Identification

What information attributes to track depends on:

- Needs of organization/risk management efforts
- Management needs of information security/information technology communities

Asset attributes to be considered are:

- Name (device or program name)
- IP address
- Media access control (MAC) address
- Element type – server, desktop, etc. Device Class, Device OS, Device Capacity

Hardware, Software, and Network Asset Identification

serial number

manufacturer name; model/part number

software versions

physical or logical location

Software version, update revision

Physical location

Logical location
- Where on network

Controlling entity
- Organization unit to which it belongs

Information Asset Classification

Many organizations have data classification schemes (e.g., confidential, internal, public data)

Classification must be specific enough to allow determination of priority

Comprehensive – all info fits in list somewhere

Mutually exclusive – fits in one place

Information Asset Valuation

Questions help develop criteria for asset valuation: which information asset

- is most critical to organization's success?
- generates the most revenue?
- generates the most profit?
- would be most expensive to replace?

Information Asset Valuation

Questions help develop criteria for asset valuation: which information asset

- would be most expensive to protect?
- would be most embarrassing or cause the greatest liability is revealed?

System Name: SLS E-Commerce
Date Evaluated: February 2003
Evaluated By: D. Jones

Information assets	Data classification	Impact to profitability
Information Transmitted:		
EDI Document Set 1 —Logistics BOL to outsourcer (outbound)	Confidential	High
EDI Document Set 2—Supplier orders (Outbound)	Confidential	High
EDI Document Set 2—Supplier fulfillment advice (inbound)	Confidential	Medium
Customer order via SSL (inbound)	Confidential	Critical
Customer service Request via e-mail (inbound)	Private	Medium
DMZ Assets:		
Edge Router	Public	Critical
Web server #1—home page and core site	Public	Critical
Web server #2—Application server	Private	Critical

Notes: BOL: Bill of Lading:
DMZ: Demilitarized Zone
EDI: Electronic Data Interchange
SSL: Secure Sockets Layer

Example Worksheet for the Asset Identification of Information Systems

Listing Assets in Order of Importance

Weighted factor analysis

- Calculate the relative importance of each asset

Each info asset assigned score for each critical factor (0.1 to 1.0)

- Impact to revenue
- Impact to profitability
- Impact to public image

Each critical factor is assigned a weight (1-100)

Multiply and add

TABLE 4-2 Example of a Weighted Factor Analysis Worksheet

Information asset	Criteria 1: impact to revenue	Criteria 2: impact to profitability	Criteria 3: public image impact	Weighted score
Criterion Weight (1-100) Must total 100	30	40	30	
EDI Document Set 1—Logistics BOL to outsourcer (outbound)	0.8	0.9	0.5	75
EDI Document Set 2—Supplier orders (outbound)	0.8	0.9	0.6	78
EDI Document Set 2—Supplier fulfillment advice (inbound)	0.4	0.5	0.3	41
Customer order via SSL (inbound)	1.0	1.0	1.0	100
Customer service request via e-mail (inbound)	0.4	0.4	0.9	55

Notes: EDI: Electronic Data Interchange
SSL: Secure Sockets Layer

Data Classification and Management

Variety of classification schemes used by corporate and military organizations

Georgia-Pacific Corporation (G-P) scheme

- Confidential, sensitive or proprietary
- Internal, G-P employee, authorized contractors
- External, public

U.S. military classification scheme

- Unclassified Data
- Sensitive by unclassified data
- Confidential data
- Secret data
- Top secret data

Data Classification and Management

Information owners responsible for classifying their information assets

Information classifications must be reviewed periodically

Most organizations do not need detailed level of classification used by military or federal agencies.

Data Classification and Management

Organizations may need to classify data to provide protection

- Public
- For official use only
- Sensitive
- classified

Data Classification and Management

Assign classification to all data

Grant access to data based on classification and need

Devise some method of managing data relative to classification

Security Clearances

Security clearance structure: each data user assigned a single level of authorization indicating classification level

Before accessing specific set of data, employee must meet *need-to-know* requirement

Extra level of protection ensures information confidentiality is maintained

Management of Classified Data

Storage, distribution, portability, and destruction of classified data

Information not unclassified or public must be clearly marked as such

Clean desk policy requires all information be stored in appropriate storage container daily; unneeded copies of classified information are destroyed

Dumpster diving can compromise information security

Threat and Prioritize Threats & Threat Agents

Threat	Example
Acts of human error or failure	**Accidents, employee mistakes**
Compromises to intellectual property	**Piracy, copyright infringement**
Deliberate acts of espionage or trespass	**Unauthorized access and/or data collection**
Deliberate acts of information extortion	**Blackmail or information disclosure**
Deliberate acts of theft	**Illegal confiscation of equipment or information**
Deliberate acts of sabotage or vandalism	**Destruction of systems or information**

Threat and Prioritize Threats & Threat Agents

Categories of Threat	Examples
Deliberate acts of software attacks	**Viruses, worms, macros, denial-of-service**
Forces of nature	**Fire, flood, earthquake, lightning**
Deviations in quality of service	**ISP, power, WAN service issues from service providers**
Technical hardware failures or errors	**Equipment failure**
Technical software failures or errors	**Bugs, code problems, unknown loopholes**
Technological obsolescence	**Antiquated or outdated technologies**

Threat Assessment

Realistic threats need investigation; unimportant threats are set aside

- Each of the treats must be examined to assess potential damage
- Which threats present a danger to an organization's assets?
- Which threats represent the most danger -probability of attack
- How much would it cost to recover
- Which treat requires the greatest expenditure to prevent?

Vulnerability Identification

Identify each asset and each threat it faces

Create a list of vulnerabilities

Examine how each of the threats are likely to be perpetrated

Risk Assessment

Risk assessment evaluates the relative risk for each vulnerability

Assigns a risk rating or score to each information asset

Risk Assessment

Risk =

likelihood of occurrence of vulnerability

*

value of the information asset

-

% of risk mitigated by current controls

+

uncertainty of current knowledge of vulnerability.

Likelihood

Probability that a specific vulnerability within an organization will be successfully attacked

Assign number between 0.1 – 1

Data is available for some factors

- Likelihood of fire
- Likelihood of receiving infected email
- Number of network attacks

Valuation of Information Assets

Using info from asset identification assign weighted score for the value

- 1 -100
- 100 – stop company operations
- May use broad categories
- NIST has some predefined

Identify Possible Controls

For each threat and associated vulnerabilities that have residual risk, create preliminary list of control ideas

Residual risk – risk remaining after controls are applied

Access Controls

Mandatory

- Gives user and data owners limited control over access to information
- Lattice-based
  - Users are assigned a matrix of authorizations for particular areas of access

Nondiscretionary

- Role or task based controls
- Centralized

Discretionary

- Option of the user

Problem

Information asset A has a value score of 50 and has one vulnerability. Vulnerability 1 has a likelihood of 1.0 with no current controls, & you estimate the assumptions and data are 90% accurate

Information asset B has a value score of 100 and has 2 vulnerability. Vulnerability 2 has a likelihood of 0.5 with current controls address 50% of its risk, vulnerability 3 has a likelihood of 0.1 with no current controls, & you estimate the assumptions and data are 80% accurate

Solutions

likelihood of occurrence of vulnerability * value of the information asset - % of risk mitigated by current controls + uncertainty of current knowledge of vulnerability

Asset A= (50 X 1.0)–(50 X 1.0) X0% + (50 X 1.0) X10%

= (50 X 1.0)– ((50 X 1.0)X0) +((50 X 1.0)+.1)

= 50 – 0 + 5

= 55

Asset B (V2)= (100 X .5)– (100 X .5) X50% + (100 X .5) X20%

= 50- 25 + 10 = 35

Asset B (V3)= (100 X .1)– 0% + (100 X .1) X20%

= 10 – 0 + 2

= 12

Documenting Results of Risk Assessment

Final summary comprised in ranked vulnerability risk worksheet. Table 4-8, relate to table 4-2.

Worksheet details *asset*, *asset impact*, *vulnerability*, *vulnerability likelihood*, and *risk-rating factor*.

Order by risk-rating factor

Ranked vulnerability risk worksheet is initial working document for next step in risk management process: assessing and controlling risk

Risk Identification and Assessment Deliverables

Deliverables	Purpose
Information assess classification worksheet	Assembles information about information assets and their impact on or value to the organization
Weighted criteria analysis worksheet	Assigns ranked value or impact weight to each information asset
Ranked vulnerability risk worksheet	Assigns ranked value of risk rating for each uncontrolled asset-vulnerability pair

Risk Control Strategies

Risk Control Strategies

Once ranked vulnerability risk worksheet complete, must choose one of four strategies to control each risk:

- Apply safeguards that eliminate or reduce residual risks (avoidance)
- Transfer the risk to other areas or outside entities (transference)
- Reduce the impact should the vulnerability be exploited (mitigation)
- Understand the consequences and accept the risk without control or mitigation (acceptance)

Avoidance

Attempts to prevent exploitation of the vulnerability

Preferred approach; accomplished through countering threats, removing asset vulnerabilities, limiting asset access, and adding protective safeguards

Three common methods of risk avoidance:

- Application of policy
- Training and education
- Applying technology

Transference

Control approach that attempts to shift risk to other assets, processes, or organizations

- Rethinking how services are offered
- Revising deployment models
- Outsourcing
- Purchasing insurance
- Implementing service contracts

In Search of Excellence

- Concentrate on what you do best

Mitigation

Attempts to reduce impact of vulnerability exploitation through planning and preparation

Approach includes three types of plans:

- Incident response plan (IRP)
- Disaster recovery plan (DRP)
- Business continuity plan (BCP)

Mitigation (continued)

Disaster recovery plan (DRP) is most common mitigation procedure

The actions to take while incident is in progress is defined in Incident response plan (IRP)

Business continuity plan (BCP) encompasses continuation of business activities if catastrophic event occurs

Acceptance

Doing nothing to protect a vulnerability and accepting the outcome of its exploitation

Valid only when the particular function, service, information, or asset does not justify cost of protection

Risk appetite describes the degree to which organization is willing to accept risk as trade-off to the expense of applying controls

Selecting a Risk Control Strategy

Level of threat and value of asset play major role in selection of strategy

- When a vulnerability exists--implement security control to reduce likelihood
- When a vulnerability can be exploited -- apply layered protections, architectural designs, and administrative controls
- When attacker's cost is less than potential gain -- apply protection to increase attackers costs
- When potential loss is substantial -- redesign, new architecture, controls

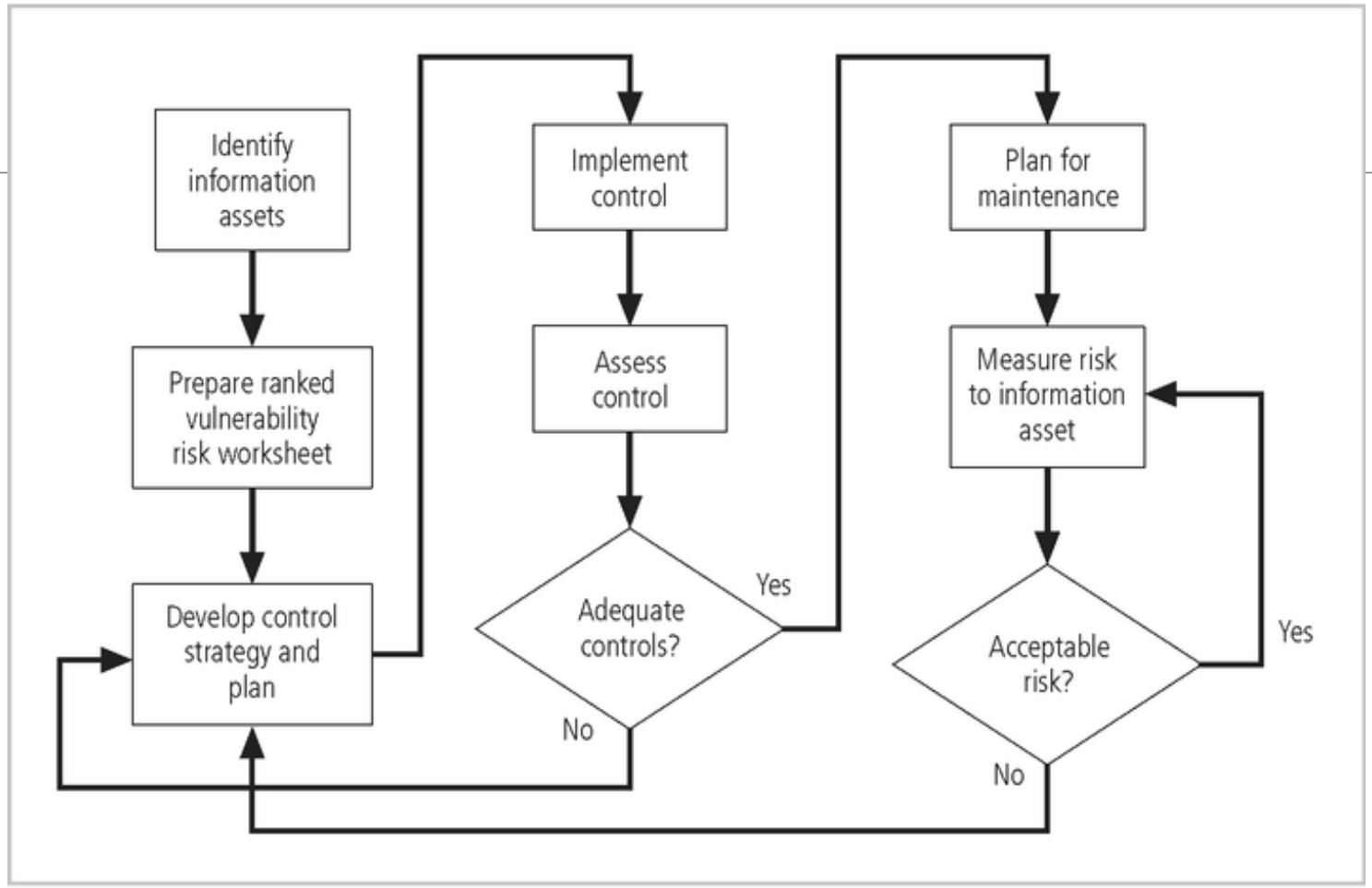


FIGURE 5-3 Risk Control Cycle[8]

Categories of Controls

1. Control function
   - Preventive & detective
2. Architectural layer
   - Organizational policy, external networks, intranets, network devices, systems
3. Strategy layer
   - Avoidance, mitigation, or transference
4. Information security principle
   - Classified by characteristics: Confidentiality, integrity, availability, authentication, authorization, accountability, privacy

Feasibility Studies

Compare cost to potential loss

Cost avoidance is the process of avoiding the financial impact of an incident

Cost Benefit Analysis

Evaluate worth of asset

Loss of value if asset compromised

Items affecting cost of control

- Cost of development or acquisition
- Cost of implementation
- Services costs
- Cost of maintenance

Benefits – value gained by using controls

Cost Benefit Analysis

Assess worth of asset

Calculate the single loss expectance

- SLE = asset value * exposure factor
- Exposure factor = % loss from exploitation

Calculate Annualized loss expectancy

- ALE = SLE * ARO (annualized rate of occurrence)

Cost Benefit Analysis Formula

CBA determines whether or not control alternative being evaluated is worth cost incurred to control vulnerability

CBA = ALE (prior) – ALE (post) – ACS

ALE(prior) is annualized loss expectancy of risk before implementation of control

ALE(post) is estimated ALE based on control being in place for a period of time

ACS is the annualized cost of the safeguard

Benchmarking

An alternative approach to risk management

Benchmarking is process of seeking out and studying practices in other organizations that one's own organization desires to duplicate

One of two measures typically used to compare practices:

- Metrics-based measures
- Process-based measures

Benchmarking --Metrics-based measures

Metrics-based measures are comparisons based on numerical standards:

- Number of successful attacks,
- staff-hours spent of systems protection,
- dollars spent on protection,
- number of security personnel,
- estimated value of info lost in attacks,
- loss in productivity hours

Performance gap is the difference between an organization's measures and those of others.

Benchmarking -- Process-based measures

Less focus on numbers

More strategic than metrics-based measures

Examine *activities* an individual company performs

Focus on *methods* to accomplish a particular process

Rather than the outcome

Benchmarking

Standard of due care: when adopting levels of security for a legal defense, organization shows it has done what any prudent organization would do in similar circumstances

Due diligence: demonstration that organization is diligent in ensuring that implemented standards continue to provide required level of protection

Failure to support standard of due care or due diligence can leave organization open to legal liability

Benchmarking – Best Practices

Best business practices: security efforts that provide a superior level protection of information

Available Resources

- Federal Agency Security Project: http://fasp.nist.gov
- CERT web site: www.cert.org/security-improvement/

Seven Key Areas of Best Practice from Microsoft

1. Use antivirus software
2. Use strong passwords
3. Verify your software security settings
4. Update product security
5. Build personal firewalls
6. Back up early and often
7. Protect against power surges and loss

Problems with Applying Benchmarking and Best Practices

Organizations don't talk to each other (biggest problem)

No two organizations are identical

Best practices are a moving target

Knowing what was going on in information security industry in recent years through benchmarking doesn't necessarily prepare for what's next

Baselining

Analysis of measures against established standards

In information security, baselining is comparison of security activities and events against an organization's future performance.

The information gathered for an organization's first risk assessment becomes the baseline for future comparison.

KEY

“the goal of information security is not to bring residual risk to zero; it is to bring residual risk into line with an organization’s comfort zone or risk appetite”

Documenting Results

At minimum, each information asset-threat pair should have documented control strategy clearly identifying any remaining residual risk, and feasibility studies to justify the findings.

Another option: document outcome of control strategy for each information asset-vulnerability pair as an action plan

Summary

Risk identification: formal process of examining and documenting risk present in information systems

Risk control: process of taking carefully reasoned steps to ensure the confidentiality, integrity, and availability of components in organization's information system

Risk identification

- A risk management strategy enables identification, classification, and prioritization of organization's information assets
- Residual risk: risk that remains to the information asset even after the existing control is applied

Summary

Risk control: four strategies are used to control risks that result from vulnerabilities:

- Apply safeguards (avoidance)
- Transfer the risk (transference)
- Reduce impact (mitigation)
- Understand consequences and accept risk (acceptance)

Components of Risk Management

